

Information Security Requirements Checklist – **Mandatory Submission**

5. Information Security Requirements Checklist		Compliance	Remarks
5.1 Information Security Governance & Policy			
5.1.1	The supplier shall maintain a documented Information Security Management System (ISMS) aligned with an internationally recognized standard (e.g., ISO/IEC 27001, NIST CSF, UAE IA) and provide evidence of certification or compliance upon request.	✓ ☐ Yes ☐ No ☐ NA	Fireware maintains an ISMS aligned with ISO/IEC 27001. Supporting certification/evidence can be provided upon request.
5.1.2	The supplier shall comply with applicable national cybersecurity policies and regulations issued by the Cyber Security Council (CSC) and provide evidence of adherence upon request.	✓ ☐ Yes ☐ No ☐ NA	Fireware complies with applicable UAE cybersecurity and regulatory requirements relevant to the services delivered to HCT. Supporting evidence can be provided upon request.
5.1.3	The supplier shall have a formally approved Information Security Policy, reviewed and updated periodically or following significant organisational or threat changes.	✓ ☐ Yes ☐ No ☐ NA	Fireware maintains documented information security policies that are periodically reviewed and updated.
5.1.4	The supplier shall designate a named Information Security Officer (ISO) or equivalent role with defined responsibilities for overseeing the security programme. (incident response, vulnerability, patch, BCDR, continuity, etc)	✓ ☐ Yes ☐ No ☐ NA	Fireware has designated responsible personnel for oversight of the information security programme, including incident response, vulnerability management, BCDR and continuity.
5.1.5	The supplier shall ensure that roles and responsibilities, and segregation of duties are formally defined, documented, and communicated to all relevant personnel.	✓ ☐ Yes ☐ No ☐ NA	Information security roles, responsibilities and segregation of duties are defined and communicated within Fireware.

5.1.6	The supplier shall maintain and make available to HCT a current register of all applicable regulatory, legal, and contractual compliance obligations relevant to information security.	✓ ☐ Yes ☐ No ☐ NA	Fireware maintains applicable legal, regulatory and contractual compliance obligations relevant to information security.
5.1.7	The supplier shall conduct formal security programme reviews at least annually with supplier's senior management sign-off.	✓ ☐ Yes ☐ No ☐ NA	Fireware conducts periodic information security programme reviews with management oversight.
5.1.8	The supplier shall maintain a security metrics programme and report agreed KPIs/KRIs to HCT on a periodic basis as agreed.	✓ ☐ Yes ☐ No ☐ NA	Security and service KPIs/KRIs will be reported to HCT as part of the agreed governance and managed-support reporting.
5.1.9	The supplier shall ensure that all subcontractors and subprocessors are bound by information security obligations no less stringent than those imposed on the supplier by HCT.	✓ ☐ Yes ☐ No ☐ NA	Subcontractors and sub-processors involved in service delivery will be subject to applicable information security obligations.

5.2.1	The supplier shall operate a documented information security risk management process aligned with an accepted framework	✓ ☐ Yes ☐ No ☐ NA	Fireware follows a documented information security risk management process covering risk identification, assessment, treatment and monitoring.
	(e.g., ISO 27001, UAE IA) covering identification, assessment, treatment, and monitoring of risks.		
5.2.2	The supplier shall conduct a formal risk assessment (aligned with HCT's IS Risk Management Processes) at least annually and whenever significant changes are made to systems, processes, or the threat landscape pertinent to services provided to HCT.	✓ ☐ Yes ☐ No ☐ NA	Security risks relevant to the HCT service will be assessed periodically and upon significant changes to the service or threat landscape.

5.2.3	The supplier shall maintain a risk register capturing identified risks, likelihood, impact, risk owners, treatment decisions, remediation timelines and residual risk levels pertinent to services provided to HCT.	☒ Yes ☐ No ☐ NA	A project/service risk register will be maintained for the HCT engagement, including risk owner, impact, likelihood, mitigation and status.
5.2.4	The supplier shall define and apply a documented risk acceptance process requiring appropriate senior management authorisation for all accepted risks (pertinent to services provided to HCT) above a defined threshold. [Risk acceptance in this context refers to the time between the identification of the risks and mitigation of the risks.]	☒ Yes ☐ No ☐ NA	Fireware applies a formal risk acceptance process with appropriate management approval.
5.2.5	The supplier shall communicate material security risks that may affect HCT's data, operations, or regulatory standing immediately after confirmation.	☒ Yes ☐ No ☐ NA	Material security risks affecting HCT will be escalated and communicated following confirmation.
5.2.6	The solution shall incorporate security risk considerations in the design, development, operations, and change management lifecycle (Security by Design).	☒ Yes ☐ No ☐ NA	Security-by-Design principles will be applied throughout design, implementation, operation and change management.
5.3.1	The solution shall support seamless integration with the HCT Identity and Access Management (IAM) solution.	☒ Yes ☐ No ☐ NA	Netskope integrates with enterprise IAM solutions, including Microsoft Entra ID, and supports identity-based policy enforcement.
5.3.2	The solution shall support role-based access control (RBAC), allowing HCT to assign permissions based on user roles and the principle of least privilege.	☒ Yes ☐ No ☐ NA	Netskope supports role-based administrative access and least-privilege assignment of permissions.
5.3.3	The solution shall support multi-factor authentication (MFA) for all user access to the solution, particularly for privileged, administrative, and remote access.	☒ Yes ☐ No ☐ NA	MFA can be enforced through integration with HCT's identity provider for user and administrative access.

5.3.4	The solution shall implement a formal access provisioning and de-provisioning process ensuring access rights are revoked	☒ Yes ☐ No ☐ NA	Access provisioning and de-provisioning can be integrated with HCT's identity lifecycle processes. Revocation timelines will follow HCT operational requirements.
-------	--	---	---

	promptly (within 24 hours for terminations) upon role change or departure.		
5.3.5	The solution shall enforce strong authentication policies including minimum password complexity, length (minimum 14 characters), and account lockout after a configurable number of failed attempts.	☒ Yes ☐ No ☐ NA	Strong authentication policies, including password complexity, length and lockout, can be enforced through HCT's identity provider.
5.3.6	The solution shall support integration with HCT's identity provider (e.g., Microsoft Entra ID / Azure AD) via SAML 2.0 or OpenID Connect (OIDC) for Single Sign-On (SSO).	☒ Yes ☐ No ☐ NA	Netskope supports SSO integration with Microsoft Entra ID/Azure AD and other enterprise IdPs through supported federation mechanisms.
5.3.7	The supplier shall conduct formal access reviews at least every six months (quarterly for privileged accounts) to validate all user access rights remain appropriate.	☒ Yes ☐ No ☐ NA	Periodic access reviews will be performed in accordance with HCT governance requirements.
5.3.8	The solution shall enforce separate privileged access mechanisms (e.g., PAM) for administrative and service accounts, with full session logging.	☒ Yes ☐ No ☐ NA	Administrative access is controlled and auditable and can be integrated with HCT's privileged-access-management processes.
5.3.9	The solution shall not permit shared or generic user accounts; all accounts shall be uniquely attributable to an individual.	☒ Yes ☐ No ☐ NA	Named user accounts will be used for administrative access; shared generic administrative accounts are not required.

5.3.10	The solution shall automatically terminate or lock inactive user sessions after a configurable inactivity timeout period.	✓ ☐ Yes ☐ No ☐ NA	Administrative sessions can be controlled through configurable session and authentication policies.
5.2.11	All default vendor-supplied credentials shall be changed before delivery or first use. No hardcoded credentials may exist in any delivered component.	✓ ☐ Yes ☐ No ☐ NA	Default vendor credentials will be changed or secured before production use; no default administrative credentials will remain active.
5.4.1	All HCT data must be encrypted in transit using TLS 1.2 or higher. TLS 1.0 and 1.1 must be disabled.	✓ ☐ Yes ☐ No ☐ NA	The proposed solution supports encrypted communications using TLS 1.2 or higher. Deprecated TLS versions will not be used for HCT service communications.
5.4.2	All HCT data stored at rest must be encrypted using AES-256 or an equivalent approved cipher.	✓ ☐ Yes ☐ No ☐ NA	HCT data at rest will be encrypted using strong industry-standard encryption. Exact cipher implementation can be confirmed by Netskope.
5.4.3	HCT data must be stored and processed only within data centres or regions explicitly approved by HCT in writing. Crossborder data transfers require prior HCT approval.	✓ ☐ Yes ☐ No ☐ NA	Netskope provides UAE NewEdge data centres and regional processing capabilities. Final storage/processing locations will be aligned with HCT-approved residency requirements.
5.4.4	Upon contract termination or at HCT's request, all HCT data must be returned in a usable format and then securely and verifiably deleted from all vendor systems within 30 days.	✓ ☐ Yes ☐ No ☐ NA	HCT data will be returned and securely deleted in accordance with the agreed contractual

			termination and data-deletion requirements.
--	--	--	---

5.4.5	The vendor must not use HCT data for any purpose other than service delivery (e.g., no use for training AI models, analytics, or advertising).	✓ ☐ Yes ☐ No ☐ NA	HCT data will be processed only for delivery of the contracted services and not for unrelated advertising or customer-specific AI model training.
5.4.6	The solution shall support configurable data retention periods aligned with HCT's requirements, and shall be capable of enforcing automated deletion at end of retention.	✓ ☐ Yes ☐ No ☐ NA	Netskope supports configurable data retention and the proposed scope includes extended data-retention capabilities.
5.4.7	The supplier shall handle data in accordance with controls aligned with HCT data classification scheme.	✓ ☐ Yes ☐ No ☐ NA	Netskope DLP and classification-aware controls can be aligned with HCT's data-classification scheme.
5.4.8	HCT data shall be stored and processed within data centres and regions explicitly approved by HCT in writing. Crossborder data transfers require prior HCT approval.	✓ ☐ Yes ☐ No ☐ NA	Same as 5.4.3. Processing and storage locations will be aligned with HCT-approved regions.
5.4.9	The supplier shall process personal data only in accordance with HCT's documented instructions and applicable data protection laws.	✓ ☐ Yes ☐ No ☐ NA	Personal data will be processed in accordance with HCT instructions and applicable data-protection requirements.
5.4.10	The supplier shall maintain a current Record of Processing Activities (RoPA) covering all personal data processed on behalf of HCT.	✓ ☐ Yes ☐ No ☐ NA	Applicable Records of Processing Activities will be maintained for personal data processed in connection with the service.

5.4.11	The solution shall enforce data minimisation principles, collecting and retaining only the minimum personal data necessary.	✓ ☐ Yes ☐ No ☐ NA	Data-minimisation principles will be followed and only information required for service delivery and security will be processed.
5.4.12	The supplier shall implement and maintain documented data retention and secure disposal policies, ensuring data is deleted or destroyed in a verifiable manner.	✓ ☐ Yes ☐ No ☐ NA	Fireware/Netskope maintain data-retention and secure-disposal processes applicable to service data.
5.4.13	The solution shall provide mechanisms to fulfil Data Subject Access Requests (DSARs), right to erasure, and other data subject rights within legally required timeframes.	✓ ☐ Yes ☐ No ☐ NA	Applicable processes will support HCT's data-subject rights, including access and erasure requirements, where relevant to data processed by the service.
5.4.14	The supplier shall conduct Data Protection Impact Assessments (DPIAs) for high-risk processing activities.	✓ ☐ Yes ☐ No ☐ NA	DPIAs will be supported/performed where required for high-risk personal-data processing.
5.4.15	The solution shall prevent unauthorised copying, printing, downloading, or exfiltration of classified data through technical controls (e.g., DLP, access restrictions).	✓ ☐ Yes ☐ No ☐ NA	Netskope DLP, RBI and Enterprise Browser controls can prevent or restrict unauthorized copying, printing, downloading and exfiltration of sensitive information.
5.4.16	The supplier shall immediately notify HCT of any personal data breach within the timeframes specified in the contract.	✓ ☐ Yes ☐ No ☐ NA	Fireware will notify HCT of confirmed personal-data breaches within the timelines agreed in the contract.

5.5.1	The solution shall implement network segmentation and zoning principles to separate production, development, and testing environments and to isolate sensitive system components from less trusted networks.	✓ ☐ Yes ☐ No ☐ NA	The proposed architecture applies segmentation and Zero Trust principles and supports separation of production and non-production environments where applicable.
5.5.2	The solution shall deploy and maintain next-generation firewalls (NGFW) with documented, reviewed, and approved rule sets.	✓ ☐ Yes ☐ No ☐ NA	Netskope Cloud Firewall/FWaaS provides cloud-delivered NGFW-equivalent policy enforcement with centrally managed rule sets.
5.5.3	The solution shall enforce encrypted communications for all data in transit using TLS 1.2 or higher and disable deprecated protocols.	✓ ☐ Yes ☐ No ☐ NA	The solution supports TLS 1.2 or higher for encrypted communications and secure inspection.
5.5.4	The solution shall implement intrusion detection and/or prevention systems (IDS/IPS) to detect and alert on or block malicious network activity.	✓ ☐ Yes ☐ No ☐ NA	Netskope Threat Protection and Cloud Firewall provide inline threat detection/prevention and IPS-type security controls.
5.5.5	The solution shall secure all remote access to internal systems via approved encrypted VPN or ZTNA mechanisms with MFA enforced.	✓ ☐ Yes ☐ No ☐ NA	Netskope One Private Access provides ZTNA-based encrypted remote access with identity/MFA integration.
5.5.6	The supplier shall maintain and regularly review network architecture documentation, including data flow diagrams.	✓ ☐ Yes ☐ No ☐ NA	Fireware will maintain HLD, LLD, as-built architecture and data-flow documentation as part of the project deliverables.

5.5.6	The solution shall implement DNS security controls (DNSSEC, DNS filtering) and email security standards (SPF, DKIM, DMARC).		Netskope provides DNS Security and DNS filtering. SPF, DKIM and DMARC are email-security controls and are outside the proposed SASE scope.
5.5.7	The solution shall prohibit unauthorised wireless access points and enforce security controls (WPA3, 802.1X) on approved wireless networks.	☐ Yes ☐ No ☐ ✓ NA	Wireless infrastructure controls such as WPA3 and 802.1X on access points are outside the scope of the proposed SASE solution.
5.5.8	The solution shall implement DDoS mitigation controls or services to protect the availability of internet-facing services.	☐ Yes ☐ No ☐ ✓ NA	DDoS mitigation for HCT internet-facing services is not included in the proposed SASE scope.